

MAPEO NORMATIVO DETALLADO

Cada Pregunta de la Encuesta → Requisitos Regulatorios

RGPD • AI Act • NIS2 • ENS • LIINE4DU • ISO/IEC

"La normativa no es el enemigo del negocio: es el mapa que evita que el negocio se pierda en el bosque regulatorio."

INSTRUCCIONES DE USO

Esta tabla mapea cada pregunta de la encuesta con:

- **Artículo(s) RGPD** directamente aplicables
- **Artículo(s) AI Act** cuando el ítem tiene dimensión de IA
- **Requisito NIS2** cuando aplica a operadores esenciales/importantes
- **Requisito ENS** para organismos del sector público
- **Categoría LIINE4DU** (adaptación AEPD de LINDDUN)
- **Norma ISO** de referencia técnica
- **Nivel de riesgo regulatorio** si la respuesta es A o B (riesgo de infracción)

MÓDULO 0 — PERFIL ORGANIZACIONAL

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P0.4 — Designación DPO	Arts. 37–39 RGPD; Art. 34 LOPDGDD	—	—	—	—	ISO 27701 §5.2	 Alto: infracción directa si DPO es obligatorio
P0.5 — Rol encuestado	Art. 24 (responsable del tratamiento)	—	—	ENS: rol RSSI	—	ISO 27001 §5.3	—

MÓDULO 1 – VINCULACIÓN (LINKING)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P1.1 Cartografía DFD / Registro de Actividades	Art. 30 RGPD (Registro de actividades); Art. 25 (PbD/PbDf)	Annex IV AI Act (documentación técnica)	Art. 21.2 NIS2 (gestión de activos)	ENS: medida op.pl.1 (Análisis de riesgos)	L – Linking	ISO 27701 §7.2.1; ISO 27001 A.8.1	● Muy alto: Art. 30 obliga al Registro de actividades
P1.2 Quasi-identificadores	Art. 5.1.e (limitación del plazo); Art. 25 (minimización); Art. 4.5 (seudonimización)	—	—	—	L – Linking; I – Identifyin g	ISO 29101; ISO 29134	⚠ Alto: riesgo de re-identificación no evaluada
P1.3 Controles anti-vinculación	Art. 25.1 RGPD (PbD); Art. 32.1.a (seudonimización)	Art. 10 AI Act (calidad de datos)	Art. 21.2.h (seguridad del suministro o cadena)	ENS: mp.si.2 (Criptografía)	L – Linking	ISO 27001 A.8.11; ISO 29101	⚠ Medio-alto
P1.4 Perfilado y group profiling	Art. 22 RGPD (decisiones automatizadas); Art. 21 (oposición); Cdo. 71	Art. 6, 13 AI Act (sistemas alto riesgo)	—	—	L – Linking; I – Identifyin g	ISO 27701 §7.3.5	⚠ Alto: Art. 22 requiere salvaguardas específicas
P1.5 Vinculación en ML/IA	Art. 25, 35 RGPD (EIPD para ML); Cdo. 75 (perfilado)	Arts. 9, 10, 13 AI Act	—	—	L – Linking; I – Identifyin g	ISO 42001 §6.1; ISO 27701 §7.2.8	● Muy alto: EIPD obligatoria para ML con riesgo alto

MÓDULO 2 — IDENTIFICABILIDAD (IDENTIFYING)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P2.1 K-anonimato en datos publicados	Art. 4.1 (datos personales); Art. 5.1.e (minimización); Art. 89 (anonimización para investigación)	—	—	—	I – Identifying	ISO 29101; ISO 20889 (técnicas de privacidad)	⚠ Alto: anonimización falsa = datos personales con protección RGPD
P2.2 Datos biométricos	Art. 9 RGPD (categorías especiales); Art. 35 (EIPD obligatoria); Art. 22 LOPDGDD	Art. 5.1.e AI Act (prohibición reconocimiento facial en espacio público)	—	ENS: datos especiales, categoría alta	I – Identifying; D – Detecting	ISO 27701 §7.2.3	🔴 Máximo: Caso AENA – 10,04 M€. EIPD es obligatoria
P2.3 Ataques de re-identificación en IA	Art. 32 RGPD (seguridad del tratamiento); Art. 35 (EIPD)	Art. 9 AI Act (exactitud y robustez)	Art. 21.2 NIS2	—	I – Identifying	ISO 42001 §6.1.2; ISO 27001 A.5.23	⚠ Alto: fallo de seguridad técnica + responsabilidad de data breach
P2.4 Identificación indirecta (cookies/tracking)	Arts. 13–14 RGPD (información); Art. 6 (base legitimadora); Directiva ePrivacy; LOPDGDD Art. 22	—	—	—	I – Identifying; U – Unawareness	ISO 27701 §7.3.2	🔴 Muy alto: área de máxima actividad sancionadora AEPD 2023–2025

MÓDULO 3 — NO REPUDIO (NON-REPUDIATION)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P3.1 Política de retención de logs	Art. 5.1.e RGPD (limitación del plazo); Art. 30 (Registro actividades); Art. 32 (seguridad)	—	Art. 21.2 NIS2 (trazabilidad)	ENS: op.exp.8 (Registro de actividades del operador); op.exp.10 (Protección de registros)	NR – Non-repudiation	ISO 27001 A.8.15 (Logging); ISO 27701 §8.4.2	⚠ Alto: retención indefinida = violación Art. 5.1.e; sin retención = incumplimiento NIS2/ENS
P3.2 Registros IA conversacional	Art. 5.1.a (transparencia); Art. 13 (información); Art. 5.1.e (retención)	Art. 13 AI Act (transparencia usuarios); Art. 52 (obligaciones de transparencia)	—	—	NR – Non-repudiation; U – Unawareness	ISO 42001 §8.4; ISO 27701 §7.3.2	🔴 Muy alto: combinación de infracción Arts. 13 + 5.1.e RGPD
P3.3 Firma digital y no repudio	Art. 7 RGPD (consentimiento documentado); eIDAS2 (2024/1183); Directiva de Firmas	—	—	ENS: mp.si.3 (Firma electrónica)	NR – Non-repudiation	ISO 27001 A.5.36; ETSI EN 319 series	⚠ Medio: riesgo jurídico ante disputas contractuales
P3.4 Derecho al olvido y supresión histórica	Art. 17 RGPD (derecho de supresión); Art. 19 (notificación a terceros); LOPDGDD Art. 15	—	—	ENS: retención documental vs. protección de datos	NR – Non-repudiation; DD – Data Disclosure	ISO 27701 §7.3.4 (Supresión de PII)	🔴 Muy alto: incumplimiento Art. 17 = infracción grave

MÓDULO 4 — DETECCIÓN (DETECTING)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P4.1 Monitorización de red / empleados	Art. 6 RGPD (base legitimadora); Art. 88 (datos laborales); LOPDGDD Art. 87-91 (privacidad en el trabajo)	—	Art. 21.2 NIS2 (monitorización como medida obligatoria)	ENS: op.exp.9 (Registro de la actividad de los usuarios)	D – Detecting	ISO 27701 §7.2.6; ISO 27001 A.6.4	⚠ Alto: monitorización sin informar = infracción LOPDGDD Art. 87
P4.2 IoT y detección de presencia	Art. 35 RGPD (EIPD para IoT alto riesgo); Art. 25 (PbD)	Art. 6 AI Act (IA en infraestructuras)	Art. 21.2 NIS2 (seguridad dispositivos conectados)	ENS: Infraestructuras críticas	D – Detecting; L – Linking	ISO 27701 §7.4.2; ETSI EN 303 645 (IoT)	⚠ Alto: tratamiento de datos de presencia sin EIPD
P4.3 Videovigilancia	Art. 22 LOPDGDD (videovigilancia); Art. 9 RGPD si hay análisis biométrico; Instrucción 1/2006 AEPD	Art. 5.1.d AI Act (prohibición reconocimiento en tiempo real si Categoría III)	—	ENS: videocámaras en instalaciones	D – Detecting; I – Identifying	ISO 27701 §7.2.3	🔴 Muy alto: videovigilancia sin cumplir Art. 22 LOPDGDD

P4.4 Side-channel / canales laterales	Art. 32 RGPD (seguridad técnica adecuada) ; Art. 35 (EIPD para tecnologías innovadoras)	Art. 9.2 AI Act (robustez y ciberseguridad)	Art. 21.2 NIS2	ENS: mp.si.2 (Criptografía)	D – Detecting	ISO 27001 A.8.16; NIST SP 800-90B	⚠ Medio: emergente como vector de riesgo en sistemas IoT y wearables
--	---	---	----------------	-----------------------------	---------------	-----------------------------------	--

MÓDULO 5 — DIVULGACIÓN DE DATOS (DATA DISCLOSURE)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P5.1 Minimización de datos	Art. 5.1.c RGPD (minimización de datos); Art. 25.2 (PbDf: mínima cantidad de datos por defecto)	Art. 10.3 AI Act (minimización en datos de entrenamiento)	—	—	DD – Data Disclosure	ISO 27701 §7.4.1; ISO 29101 §8.3	● Muy alto: principio básico del RGPD; infracción frecuente en auditorías
P5.2 IA Generativa y privacidad	Art. 6 RGPD (base legitimada del tratamiento de prompts); Art. 32 (seguridad); Art. 35 (EIPD para LLMs)	Arts. 10, 13, 53 AI Act (GPAI: transparencia, protección de datos, cumplimiento copyright)	—	—	DD – Data Disclosure ; I – Identifying	ISO 42001 §8.3; EDPB Report LLMs 2025	● Muy alto: área de máxima atención regulatoria en 2025–2026
P5.3 Transferencias internacionales	Arts. 44–49 RGPD (transferencias internacionales); Decisión de adecuación UE-EE.UU. (DPF 2023)	Art. 10 AI Act (datos de entrenamiento transfronterizos)	Art. 21.5 NIS2 (cadena de suministro)	—	DD – Data Disclosure	ISO 27701 §8.5; SCC UE (2021)	● Muy alto: multa TikTok 530 M€ (2025) por transferencias ilegales

P5.4 Encargados del tratamiento	Art. 28 RGPD (contratos DPA); Art. 29 (instrucciones al encargado); Art. 82 (responsabilidad)	Art. 28 AI Act (obligaciones del operador)	Art. 21.2 NIS2 (seguridad de cadena de suministro)	ENS: subcontratación	DD – Data Disclosure	ISO 27701 §6.12; ISO 27001 A.5.19– 5.22	⚠ Alto: responsabilidad solidaria por incumplimiento del encargado
P5.5 Retención y derecho al olvido técnico	Art. 5.1.e RGPD (limitación del plazo); Art. 17 (supresión); Art. 25.2 (PbDf)	—	—	ENS: retención de registros	DD – Data Disclosure ; NR – Non- repudiation	ISO 27701 §7.3.5; ISO 27001 A.8.10	⚠ Alto: retención innecesaria = volumen excesivo de datos expuestos en brecha

MÓDULO 6 — DESCONOCIMIENTO (UNAWARENESS)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P6.1 Calidad de la información	Arts. 13–14 RGPD (información al interesado); Art. 5.1.a (transparencia); Directrices GT29 WP260	Art. 13 AI Act (transparencia a usuarios de IA de alto riesgo); Art. 52 (chatbots)	—	—	U – Unawareness	ISO 27701 §7.3.2	● Muy alto: incumplimiento Arts. 13–14 = infracción muy grave
P6.2 Gestión del consentimiento	Art. 7 RGPD (condiciones del consentimiento); Art. 4.11 (definición); Directrices GT29 WP259	Art. 13 AI Act (información previa a uso)	—	—	U – Unawareness	ISO 27701 §7.2.3; IAB TCF v2.2	● Muy alto: consentimiento inválido = base jurídica inexistente
P6.3 Ejercicio de derechos ARCO+	Arts. 15–22 RGPD (derechos de los interesados); Arts. 12.3 (plazo 30 días); LOPDGDD Arts. 12–18	—	—	—	U – Unawareness; Exclusion (LIINE4DU)	ISO 27701 §7.3.4	⚠ Alto: incumplimiento de plazos = reclamaciones ante AEPD

P6.4 Decisiones automatizadas	Art. 22 RGPD (decisiones automatizadas y perfilado); Cdo. 71; Directrices GT29 WP251	Arts. 13, 14, 86 AI Act (derecho a explicación para IA de alto riesgo)	—	—	U – Unawareness; L – Linking	ISO 27701 §7.3.5	● Muy alto: combinación Art. 22 RGPD + AI Act de alto riesgo
P6.5 Formación en privacidad	Art. 39.1.b RGPD (función del DPO: concienciación); Art. 32.4 (formación como medida de seguridad)	Art. 4.2 AI Act (alfabetización en IA)	Art. 20 NIS2 (formación de órganos de dirección)	ENS: mp.per.2 (Formación y concienciación)	U – Unawareness	ISO 27001 A.6.3; ISO 27701 §5.3	⚠ Medio- alto: personal sin formación = vector de brecha humana

MÓDULO 7 — INCUMPLIMIENTO (NON-COMPLIANCE)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P7.1 Gap analysis regulatorio	Art. 24 RGPD (responsabilidad proactiva); Art. 32 (medidas técnicas y organizativas)	Arts. 9, 17 AI Act (sistemas de gestión de riesgos)	Art. 21 NIS2 (obligaciones de seguridad)	ENS: op.pl.1 (Análisis de riesgos)	NC – Non-compliance	ISO 27001 §6.1.2; ISO 27701 §5.2.1	⚠ Alto: ausencia de gap analysis impide defensa de diligencia debida
P7.2 EIPDs / DPIAs	Art. 35 RGPD (EIPD obligatoria); Art. 36 (consulta previa); Directrices GT29 WP248; Listado AEPD	Art. 27 AI Act (evaluación de impacto en derechos fundamentales)	—	—	NC – Non-compliance; Data Breach (LIINE4DU)	ISO 29134 (EIPD); ISO 27701 §7.2.8	● Máximo: multa AENA 10,04 M€ por EIPD inválida (2025)
P7.3 Cumplimiento AI Act	—	Arts. 5, 6, 9, 10, 13, 17, 22, 27 AI Act; Plazos de cumplimiento 2025–2027	—	—	NC – Non-compliance	ISO 42001 (SGAI)	● Muy alto: sanciones hasta 35 M€ o 7% facturación global
P7.4 Gestión de brechas	Arts. 33–34 RGPD (notificación de brechas); Directrices GT29 WP250; LOPDGDD	—	Art. 23 NIS2 (notificación de incidentes: 24h alerta + 72h notificación)	ENS: op.exp.7 (Gestión de incidentes de seguridad)	Data Breach (LIINE4DU)	ISO 27001 A.5.24–5.28; ISO 27035	● Muy alto: incumplimiento plazo 72h = infracción directa Arts. 33 RGPD

P7.5 Relación con AEPD	Art. 31 RGPD (cooperación con autoridad); Art. 58 (poderes de investigación)	—	Art. 32 NIS2 (supervisión)	—	NC – Non-compliance	—	⚠ Medio: relación reactiva aumenta exposición ante inspecciones
---------------------------------------	---	---	----------------------------------	---	---------------------	---	--

MÓDULO 8 — INEXACTITUD Y EXCLUSIÓN (LIINE4DU)

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P8.1 Integridad y exactitud de datos	Art. 5.1.d RGPD (exactitud); Art. 16 (rectificación); Art. 5.1.f (integridad y confidencialidad)	Art. 10 AI Act (calidad de datos de entrenamiento y validación)	—	—	Inaccuracies (LIINE4DU)	ISO 8000 (calidad del dato); ISO 27701 §7.4.1	⚠ Alto: datos inexactos que generan decisiones erróneas = daño a interesados
P8.2 Sesgo en IA	Art. 22 RGPD (perfilado discriminatorio) + Cdo. 71; Arts. 14, 27 AI Act	Arts. 9, 10, 15 AI Act (exactitud, robustez, no discriminación)	—	—	Inaccuracies (LIINE4DU)	ISO 42001 §9.1; IEEE 7003 (Transparencia algorítmica)	🔴 Muy alto: sesgo en IA de alto riesgo = infracción directa AI Act + RGPD Art. 22
P8.3 Exclusión y barreras de acceso	Art. 12 RGPD (comunicación accesible); Art. 5.1.a (transparencia); LOPDGDD + LGDPD	Art. 14 AI Act (supervisión humana accesible)	—	ENS: accesibilidad de servicios digitales	Exclusion (LIINE4DU)	ISO 9241-171 (Accesibilidad SW); WCAG 2.1 AA	⚠ Medio-alto: discriminación digital + incumplimiento Art. 12 RGPD

MÓDULO 9 — GOBERNANZA

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P9.1 Privacidad en estrategia corporativa	Art. 24 RGPD (responsabilidad proactiva); Art. 42 (certificación voluntaria)	Art. 26 AI Act (obligaciones del operador)	Art. 20 NIS2 (supervisión del órgano de dirección)	ENS: Política de seguridad (cat. alta)	Todos	ISO 27701 \$5.1; ISO 42001 \$5.1	⚠ Medio: ausencia de gobernanza = riesgo sistémico
P9.2 Presupuesto de privacidad	Art. 24 RGPD (medidas apropiadas teniendo en cuenta los costes)	Art. 9 AI Act (recursos para gestión de riesgos)	Art. 21.1 NIS2 (proporcionalidad de medidas)	ENS: marco presupuestario de seguridad	Todos	ISO 27001 \$6.3; ISO 27701 \$6.3	⚠ Medio: insuficiencia presupuestaria documentada puede ser agravante
P9.3 KPIs y métricas de privacidad	Art. 24.1 RGPD (demostrar cumplimiento); Art. 5.2 (principio de responsabilidad proactiva)	Art. 9.7 AI Act (registros automáticos + supervisión)	Art. 21.2 NIS2 (evaluación periódica)	ENS: métricas de cumplimiento	Todos	ISO 27701 \$9.1; ISO 27001 \$9.1	⚠ Alto: sin métricas no hay evidencia de cumplimiento demostrable

MÓDULO 10 — TECNOLOGÍA E IA

Pregunta	RGPD	AI Act	NIS2	ENS	LIINE4DU	ISO	Riesgo (Resp. A/B)
P10.1 Inventario de sistemas IA	Art. 30 RGPD (registro incluye sistemas automatizados); Art. 35 (EIPD por sistema)	Arts. 6, 9, 11 AI Act (clasificación de riesgo + registro UE para sistemas alto riesgo)	—	—	NC – Non-compliance	ISO 42001 §8.2; NIST AI RMF 1.0	● Muy alto: sistemas de alto riesgo no registrados = infracción directa AI Act
P10.2 IA Agéntica	Art. 22 RGPD (decisiones automatizadas con efectos significativos)	Art. 22 AI Act (medidas de supervisión humana); Art. 13 (transparencia)	—	—	L + D + NR (todos activados)	ISO 42001 §8.4; EDPB LLM Report 2025	● Muy alto: agentes autónomos con efectos sobre personas = zona de máximo riesgo
P10.3 Continuidad de negocio con privacidad	Art. 32.1 RGPD (planes de contingencia); Art. 33 (brechas como evento de continuidad)	—	Arts. 20–21 NIS2 (gestión de continuidad)	ENS: op.cont (Continuidad del servicio)	Data Breach (LIINE4DU)	ISO 22301 (SGCN); ISO 27001 A.5.30	⚠ Alto: brecha no gestionada como evento de continuidad = agravante sancionador
P10.4 Zero Trust y privacidad	Arts. 25, 32 RGPD (seguridad + PbD)	Art. 9.5 AI Act (ciberseguridad)	Art. 21.2.b NIS2 (gestión de identidad y acceso)	ENS: ZTA en implementación (guía CCN 2025)	L + D + NR (mitigados por ZTA)	ISO 27001 A.5.15–5.18; NIST SP 1800-35	⚠ Medio-alto: arquitecturas sin ZTA aumentan superficie de Linking y Detecting

RESUMEN EJECUTIVO DE RIESGOS REGULATORIOS

Ítems con Riesgo Máximo (● si respuesta es A o B)

Pregunta	Infracción Principal	Sanción Máxima Aplicable
P2.2 (Datos biométricos)	Art. 35 RGPD (EIPD obligatoria)	Hasta 20 M€ o 4% facturación global
P5.2 (IA Generativa)	Arts. 6 + 13 + 35 RGPD	Hasta 20 M€ o 4% facturación global
P5.3 (Transferencias internacionales)	Arts. 44–49 RGPD	Hasta 20 M€ o 4% facturación global
P6.1 (Información al interesado)	Arts. 13–14 RGPD	Hasta 20 M€ o 4% facturación global
P6.2 (Consentimiento inválido)	Arts. 6 + 7 RGPD	Hasta 20 M€ o 4% facturación global
P7.2 (EIPD inválida)	Art. 35 RGPD	Hasta 20 M€ o 4% facturación global
P7.3 (AI Act incumplimiento)	Arts. 5, 9, 17 AI Act	Hasta 35 M€ o 7% facturación global
P7.4 (Brecha no notificada)	Arts. 33–34 RGPD	Hasta 10 M€ o 2% facturación global
P10.1 (IA no registrada)	Arts. 6, 9, 11 AI Act	Hasta 15 M€ o 3% facturación global
P10.2 (IA agéntica sin gobernanza)	Art. 22 AI Act + Art. 22 RGPD	Hasta 35 M€ o 7% facturación global

*Mapeo normativo elaborado conforme al estado del Derecho europeo y español en abril de 2026.
Actualizado con AI Act (vigente desde agosto 2024, prohibiciones desde febrero 2025), NIS2 (transpuesta en España por Ley 11/2022 de Medidas de Seguridad de las Redes), ENS (RD 311/2022) y LIINE4DU 1.0 (AEPD, octubre 2024). Versión 1.0.*